Host Header Injection Security Testing

Educational Bug Bounty Series • Authorized Security Research Only

■ HTTP Host Header Injection — Security Testing

Contributed by Cyber_Spy.404 | Educational Bug Bounty Series

Scope and ethics: *Use authorized applications, a test domain you control, and a controlled inbox. Never send misleading links to real users.*

■ Executive Summary

Host header injection occurs when an application trusts unvalidated `Host` or forwarding headers while constructing links, redirects, or security decisions. The supplied PDF highlights password-reset/newsletter workflows, duplicate Host headers, override headers, and absolute URLs.

■ Core Testing Methodology

1. Identify URL-generating features such as password reset, invitations, newsletters, and redirects.
2. Record normal behavior using a controlled test account.
3. Verify only configured canonical hostnames are accepted.
4. Check whether forwarding headers are set only by trusted proxies.
5. Ensure duplicate Host values and ambiguous absolute-form requests are rejected.
6. Inspect generated links using a test inbox.
7. Capture minimal, redacted evidence and retest remediation.

■ High-Value Bug Bounty Tips & Edge Cases

- Password-reset and newsletter features are highlighted by the source.
- The PDF lists `X-Forwarded-For`, `X-Forwarded-Host`, `X-Client-IP`, `X-Remote-IP`, `X-Remote-Addr`, and `X-Host`.
- Forwarding headers must not be trusted when supplied directly by arbitrary clients.
- Proxy and application layers may interpret duplicate Host headers differently.
- An unexpected host value alone is not proof of impact; verify generated behavior safely.
- The source does not establish that a specific target is vulnerable.

■■ Educational Checklists & Safe Examples

```
GET /account/recovery HTTP/1.1
Host: [Your-Approved-Test-Domain]
```

```
Expected origin: https://[Configured-Canonical-Domain]
Unexpected host accepted: [Yes/No]
Evidence: [Redacted]
```

- [ ] Valid hostnames are allowlisted.
- [ ] Untrusted forwarding headers are stripped or ignored.
- [ ] Duplicate Host values are rejected.
- [ ] Email links use a configured canonical origin.
- [ ] Cache and routing behavior is consistent.

■■ Mitigation & Remediation

Use an explicit hostname allowlist, configure trusted proxies to overwrite forwarding headers, reject duplicate or malformed Host values, construct absolute links from a configured canonical origin, and test cache/routing behavior.

Source Notes

Based on the supplied two-page *HOST HEADER INJECTION.pdf*. Page 1 describes Host manipulation and duplicate headers; page 2 lists forwarding headers and absolute-URL handling and references PortSwigger.

Educational use only. Stay in scope and use controlled inboxes.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.